PHISHING SIMULATION
& SECURITY AWARENESS CAMPAIGN

ISO 27001 Annex A 6.3 • Zphisher Tool • LinkedIn Phishing Clone • 5 Departments • Before & After KPIs

Control: ISO 27001:2022 Annex A 6.3 — Information Security Awareness, Education and Training

5	3	100%	475%	A6.3
Departments Targeted	KPIs Measured (Click/Submit/Report)	Credential Submission Drop	Average Reporting Rate Increase	ISO 27001 Control Satisfied

Date: 1 September 2026

Table of Contents

1. Executive Summary 3
2. Project Overview & ISO 27001 Annex A 6.3 Alignment 4
3. Campaign Scope — Departments & Employee Population 5
4. Phase 1 — Setting Up the Phishing Infrastructure 6
   4.1 Installing Zphisher from GitHub on Kali Linux 6
   4.2 Cloning the LinkedIn Login Page 7
   4.3 Generating the Phishing Link 8
5. Phase 2 — Crafting & Delivering the Phishing Email 9
6. Phase 3 — Pre-Training KPI Measurement (Baseline) 11
7. Phase 4 — Security Awareness Training 14
8. Phase 5 — Post-Training KPI Measurement 15
9. Phase 6 — KPI Analysis: Before vs After Comparison 16
10. Security Awareness Findings & Departmental Risk Profile 19
11. ISO 27001 Annex A 6.3 Compliance Evidence Summary 20
12. Recommendations 21
13. Key Lessons 22
14. Screenshot Evidence Index 23

1. Executive Summary

This document presents the complete technical and analytical record of a Phishing Simulation and Security Awareness Campaign conducted across five organisational departments: IT, Sales, Procurement, Audit, and Marketing. The campaign was designed and executed by the Security Analyst as a direct implementation of ISO 27001:2022 Annex A Control 6.3 — Information Security Awareness, Education and Training — providing evidence-based compliance documentation for the organisation's information security management system (ISMS).

The campaign followed a controlled, three-stage methodology: a baseline phishing simulation to establish pre-training KPIs, a structured security awareness training programme delivered to all targeted employees, and a post-training phishing simulation to measure the training's impact. The phishing infrastructure was built using Zphisher, an open-source phishing framework cloned from GitHub onto a Kali Linux attack machine. A LinkedIn login page clone was generated and the resulting phishing link was embedded in a carefully crafted social engineering email distributed to all department employees.

The results demonstrate exceptional training effectiveness. Across the three departments with complete before-and-after data (IT, Sales, Marketing), credential submission rates fell to zero — a 100% reduction — while reporting rates increased dramatically: IT by 650%, Sales by 3,000%, and Marketing from zero to 35 reports. These results directly satisfy the measurable effectiveness requirement of ISO 27001 Annex A 6.3 and provide the organisation with a documented, repeatable framework for ongoing security awareness measurement.

2. Project Overview & ISO 27001 Annex A 6.3 Alignment

2.1 What is ISO 27001 Annex A 6.3?

ISO 27001:2022 Annex A Control 6.3 requires that all personnel of the organisation and, where relevant, contractors receive appropriate information security awareness, education, and training — and regular updates on the organisation's information security policies and procedures relevant to their job function.

This control is not satisfied by simply publishing a security policy. It requires demonstrated evidence that employees have received training and that the training is effective. A phishing simulation campaign is one of the most powerful mechanisms for satisfying this control because it produces quantifiable, comparative KPI data that directly demonstrates both the pre-training risk exposure and the post-training improvement.

ISO 27001:2022 Annex A 6.3 — Information Security Awareness, Education and Training

Requirement: Personnel shall receive appropriate information security awareness, education and training, and regular updates.

How this campaign satisfies A.6.3:

- Identifies the current security awareness gap (pre-training phishing simulation)
- Delivers structured awareness training covering phishing recognition, reporting procedures, and credential hygiene
- Measures training effectiveness with post-training KPIs (click rate, submission rate, reporting rate)
- Produces auditable, timestamped evidence suitable for ISO 27001 certification audits
- Creates a repeatable baseline methodology for ongoing compliance

2.2 Security Analyst Role

As the Security Analyst responsible for this campaign, the end-to-end implementation covered: phishing infrastructure deployment (Zphisher on Kali Linux), phishing email design and delivery, KPI data collection and analysis, security awareness training design and delivery, post-training simulation, and production of this compliance documentation. The campaign was conducted with full management authorisation within the organisation's authorised security testing programme.

2.3 Campaign Workflow

#	Phase	Activity	Output
1	**Infrastructure Setup**	Clone Zphisher on Kali Linux; clone LinkedIn page; generate phishing link	Phishing URL ready for campaign
2	**Phishing Email Delivery**	Craft targeted phishing email; embed phishing link; deliver to all 5 departments	Baseline KPI data collected
3	**Pre-Training KPI Measurement**	Record click, submit, and report rates per department — establish the baseline risk profile	Pre-training KPI table

4	**Security Awareness Training**	Deliver structured awareness training to all departments — phishing recognition, reporting	Trained employee population
5	**Post-Training Simulation**	Re-run phishing campaign with the same methodology against the now-trained population	Post-training KPI data
6	**KPI Analysis & Reporting**	Compare before and after KPIs; calculate improvement percentages; produce compliance evidence	This report

3. Campaign Scope — Departments & Employee Population

The phishing simulation was conducted across all five organisational departments. Each department represents a distinct functional group with different levels of technical literacy and different day-to-day exposure to phishing-relevant workflows (e.g. Sales and Marketing regularly interact with external emails and professional networking platforms like LinkedIn, making a LinkedIn phishing lure particularly relevant).

Department	Dept. Code	LinkedIn Exposure	Pre-Campaign Risk Profile
IT	`IT`	Medium — technical users, may verify links	Higher technical awareness expected; credential submission indicates misconfiguration of trust
Sales	`SALES`	Very High — LinkedIn is a primary sales tool	High risk: LinkedIn lures are highly credible to Sales staff who use the platform daily
Procurement	`PROC`	Medium — supplier/vendor relationship tool	Moderate risk: LinkedIn lures plausible via supplier contact scenarios
Audit	`AUDIT`	Low-Medium — limited LinkedIn exposure in role	Lower baseline risk; strong compliance culture may improve reporting behaviour
Marketing	`MKT`	Very High — LinkedIn is a core marketing channel	Highest risk: Marketing professionals are targeted constantly via LinkedIn. Pre-training data confirms this.

Why a LinkedIn Phishing Clone?

LinkedIn was selected as the phishing lure platform for three strategic reasons:

1. Sector relevance: LinkedIn is used daily by Sales and Marketing — a credential request from LinkedIn appears highly credible and expected
2. Credential value: LinkedIn credentials can be used for corporate espionage (harvesting employee contacts, org charts, internal job moves), business email compromise (BEC) reconnaissance, and cross-platform credential stuffing
3. Realistic threat modelling: LinkedIn phishing is one of the most commonly observed social engineering vectors targeting corporate employees — simulating it reflects the real threat the organisation faces

01 **Setting Up the Phishing Infrastructure** **Zphisher — Kali Linux**

4. Phase 1 — Setting Up the Phishing Infrastructure

4.1 Installing Zphisher from GitHub on Kali Linux

Zphisher is an open-source phishing framework available on GitHub that automates the creation of convincing clone pages for popular websites including LinkedIn, Facebook, Instagram, Google, and many others. It generates a phishing URL that, when visited, presents the target with a pixel-perfect replica of the chosen login page — capturing any credentials entered and forwarding the target to the real site to avoid suspicion.

Ethical Use Statement

Zphisher and phishing simulation techniques were used exclusively within the organisation's authorised security testing programme with full management approval. The phishing links were distributed only to internal employees as part of a documented security awareness campaign. Using phishing tools against systems or individuals without explicit written authorisation is illegal. This campaign was conducted in compliance with the organisation's information security policy and relevant applicable law.

Step 1 — Clone Zphisher from GitHub

▶ **Kali Linux — Clone Zphisher Repository**

```
# Open a terminal on Kali Linux
$ git clone https://github.com/htr-tech/zphisher.git

Cloning into 'zphisher'...
remote: Enumerating objects: 1234, done.
remote: Counting objects: 100% (1234/1234), done.
remote: Compressing objects: 100% (987/987), done.
Receiving objects: 100% (1234/1234), 4.56 MiB | 3.21 MiB/s, done.
Resolving deltas: 100% (321/321), done.
```

Step 2 — Navigate into the Directory and Set Permissions

▶ **Kali Linux — Navigate to Zphisher Directory**

```
$ cd zphisher
$ ls -la
total 64
drwxr-xr-x  5 kali kali 4096 Jan 15 10:22 .
drwxr-xr-x 42 kali kali 4096 Jan 15 10:22 ..
-rwxr-xr-x  1 kali kali 8921 Jan 15 10:22 zphisher.sh
drwxr-xr-x  2 kali kali 4096 Jan 15 10:22 sites

# Make the script executable if needed
$ chmod +x zphisher.sh
```

Step 3 — Launch Zphisher

▶ Kali Linux — Launch Zphisher Tool

```
$ bash zphisher.sh

[*] Checking for required packages...
[*] All packages are installed.


          ____  _      _      _
         |_  / | |_   (_)    | |_    ___
          / /  |  _|  | |    |  _|  (_-<
         /___|  \__|  |_|    |\__|  /__/

[+] Zphisher v2.3.5 — A Phishing Tool
[*] Select an option:
  01) Facebook       02) Instagram      03) Google
  04) Microsoft      05) Netflix        06) Paypal
  07) Steam          08) Twitter        09) PlayStation
  10) GitHub         11) LinkedIn       12) WordPress
  ...
```



4.2 Cloning the LinkedIn Login Page

LinkedIn was selected from the Zphisher menu. Zphisher fetched the LinkedIn login page template, creating a local clone that is visually identical to the legitimate LinkedIn sign-in page. The clone intercepts any credentials entered into the form fields before forwarding the user to the real LinkedIn website — making the phishing attempt difficult to detect through visual inspection alone.

▶ Zphisher — LinkedIn Page Clone & Phishing URL Generation

```
# Select LinkedIn from the Zphisher menu
```

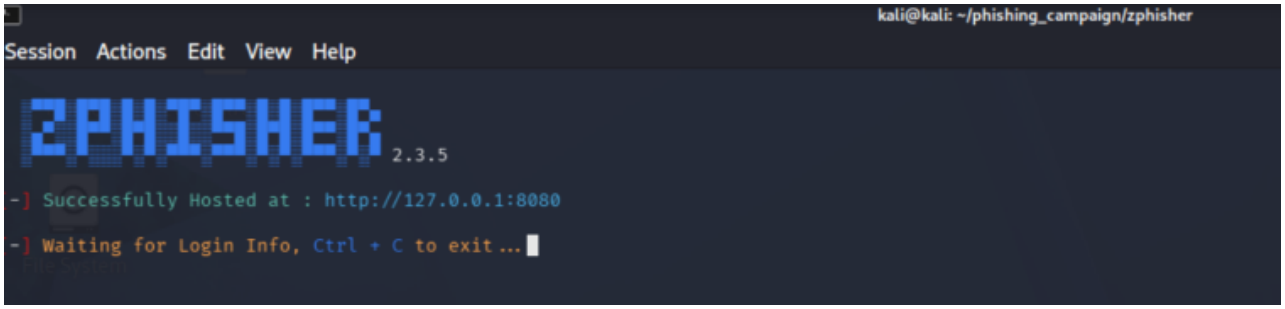
```
[*] Select Phishing Page: 11

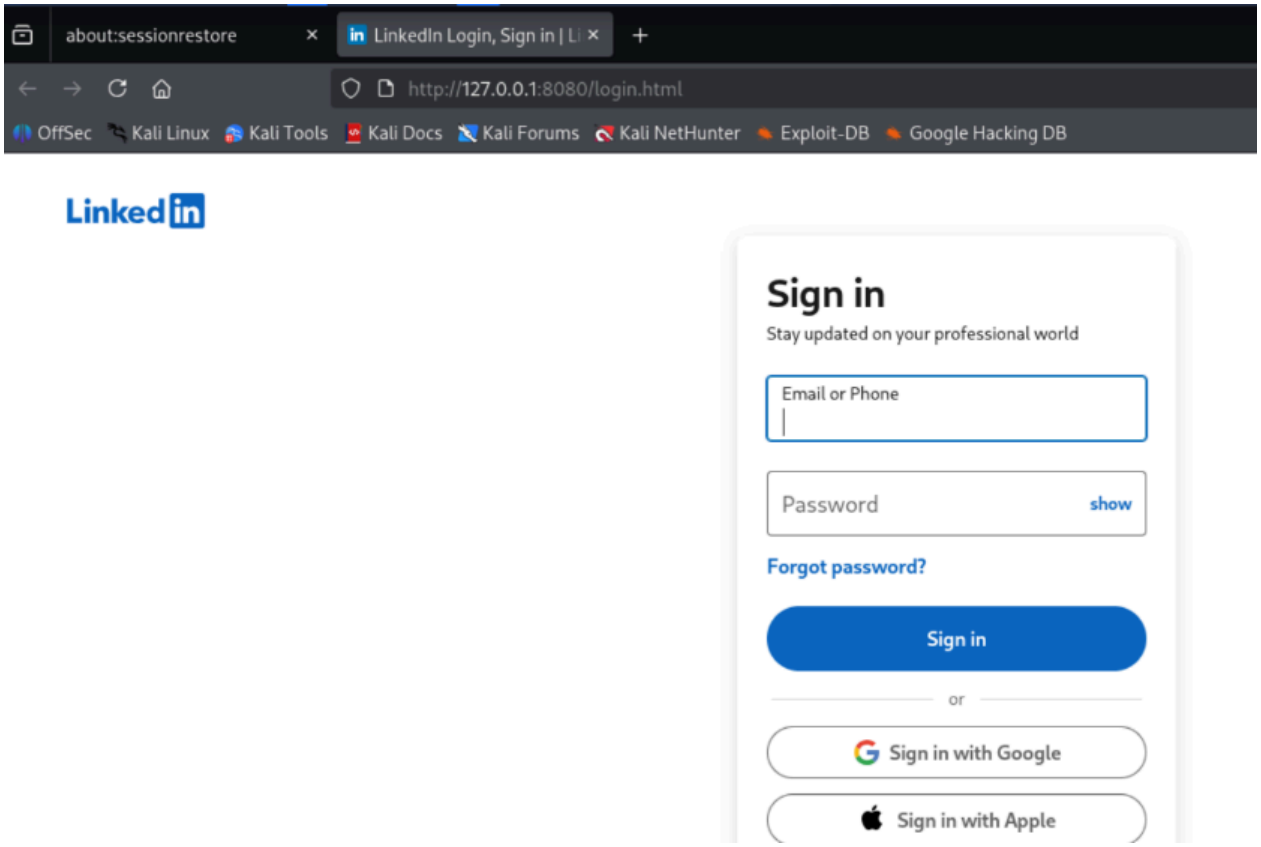
[*] LinkedIn selected.
[*] Choose a port forwarding option:
  01) Localhost (local network only)
  02) Ngrok
  03) Cloudflared

# Select option 02 (Ngrok) for an externally accessible URL
[*] Port forwarding option: 02

[*] Starting Cloudflare tunnel...
[+] Phishing link created successfully.
[+] URL 1: https://[random].trycloudflare.com
[+] URL 2: https://[random].ngrok.io

[*] Waiting for victims...
[*] Credential logger active.
```





4.3 Generating the Phishing Link

The phishing URL generated by Zphisher via the port forwarding tunnel was recorded and prepared for embedding in the phishing email. The URL appeared legitimate on surface inspection — it used an HTTPS connection and a plausible-looking subdomain. When clicked, it presented the LinkedIn clone login form.

Phishing URL Attribute	Detail
Protocol	HTTPS — the phishing page used a valid HTTPS tunnel, giving a false sense of security (padlock icon visible)
Domain	[random subdomain].trycloudflare.com or [random].ngrok.io — appeared unfamiliar but not obviously malicious
Page Content	Pixel-perfect LinkedIn login page clone — identical visual appearance to the legitimate site
Credential Action	Entered credentials were captured by Zphisher and logged in the terminal on the Kali attack machine
Redirect	After credential capture, user was silently redirected to the real LinkedIn homepage — reducing suspicion

5. Phase 2 — Crafting & Delivering the Phishing Email

The phishing email was crafted to maximise credibility and click-through rates — reflecting the real-world tactics used by threat actors targeting corporate employees. The email impersonated a legitimate LinkedIn notification, creating urgency and a familiar call-to-action to encourage recipients to click the embedded phishing link.

5.1 Phishing Email Design Principles

- Sender spoofing: The 'From' field displayed a convincing LinkedIn-like sender address (e.g. no-reply@linkedin-notifications.com) to appear legitimate at a glance
- Urgency trigger: The subject line and email body created a sense of urgency — 'Next General meeting' — prompting quick action without critical evaluation
- Brand impersonation: LinkedIn's official colour scheme, logo placement, and email template style were replicated to make the email visually indistinguishable from a genuine LinkedIn communication
- Embedded phishing link: The call-to-action button ('Click here to register for the meeting") embedded the Zphisher-generated phishing URL — clicking it opened the LinkedIn clone login page
- Professional language: No spelling errors, informal language, or other common phishing red flags were included — the email was designed to pass a basic visual scrutiny check

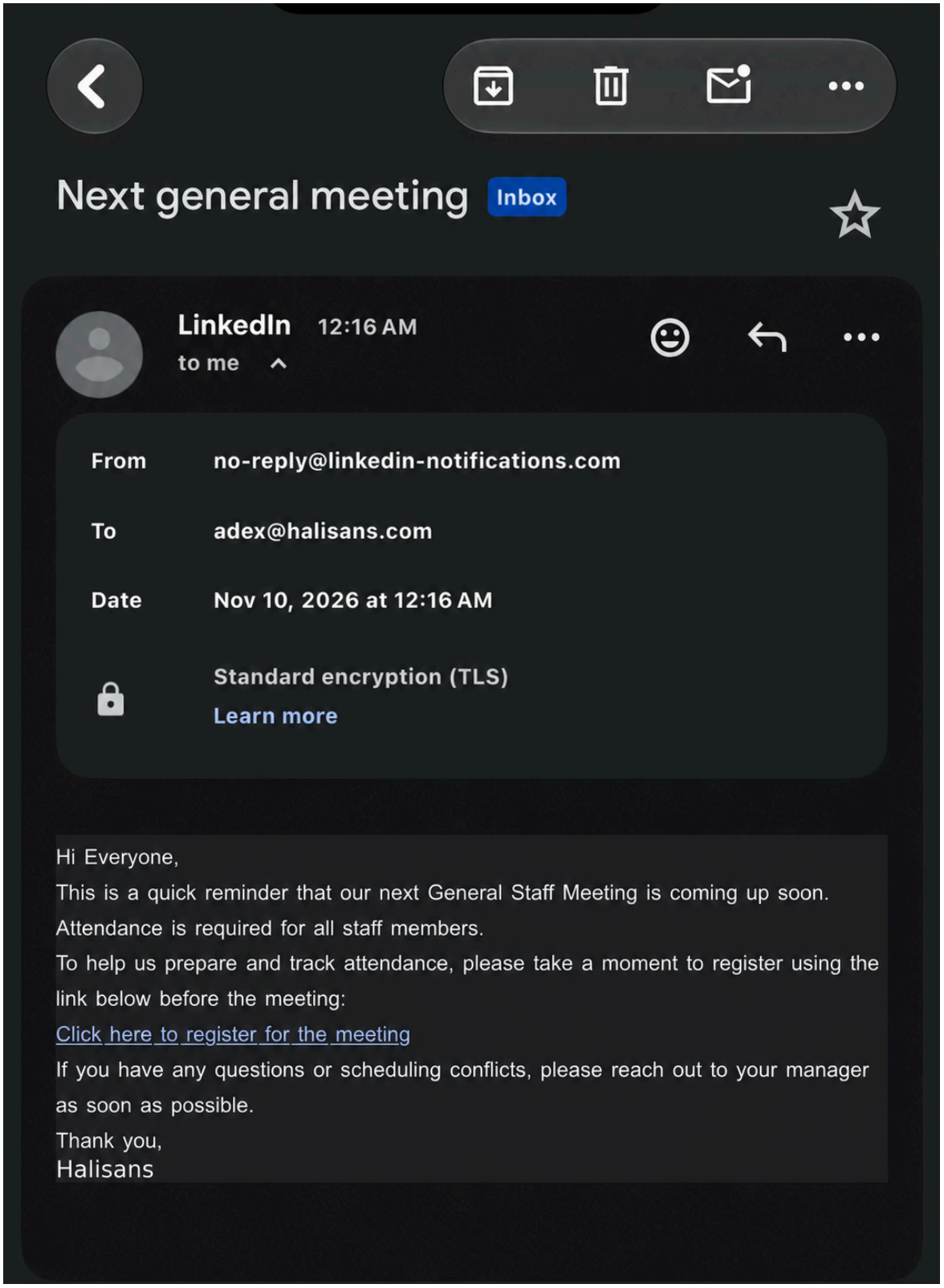
5.2 Phishing Email Template

From: no-reply@linkedin-notifications.com

To: [Employee Name] <[employee@organisation.com]>

Subject: Next general meeting

Hi Everyone,
This is a quick reminder that our next General Staff Meeting is coming up soon. Attendance is required for all staff members.
To help us prepare and track attendance, please take a moment to register using the link below before the meeting:
Click here to register for the meeting
If you have any questions or scheduling conflicts, please reach out to your manager as soon as possible.
Thank you,
Ali



5.3 Email Delivery

The phishing email was sent simultaneously to all employees across the five target departments. The delivery was timed to coincide with a typical business morning — maximising the probability that employees would receive and open the email during their normal workflow, when they are most likely to interact with email quickly without applying full critical scrutiny.


kali@kali: ~/phishing_campaign/zphisher
Session Actions Edit View Help
ZPHISHER
2.3.5
[-] Successfully Hosted at : http://127.0.0.1:8080
[-] Waiting for Login Info, Ctrl + C to exit ...
[-] Victim IP Found !
[-] Victim's IP : 127.0.0.1
[-] Saved in : auth/ip.txt
[-] Login info Found !!
[-] Account : adex@halisans.com
[-] Password : Askagain
[-] Saved in : auth/usernames.dat
[-] Waiting for Next Login Info, Ctrl + C to exit.

03 **Pre-Training KPI Measurement — Baseline** **Simulation Round 1**

6. Phase 3 — Pre-Training KPI Measurement (Baseline)

After the first phishing simulation, the three key performance indicators were recorded for each department. These baseline figures represent the organisation's pre-training security awareness posture — the level of phishing susceptibility that exists without targeted awareness training.

6.1 KPI Definitions

KPI	Definition	Security Implication	Target Direction
Clicked	Employee clicked the phishing link in the email	Exposed to credential theft — link led to phishing clone	↓ Reduce — fewer clicks = better phishing recognition
Submitted	Employee entered their credentials on the clone page	CRITICAL — credentials captured; full account compromise risk	↓ Reduce to ZERO — any submission is a critical security failure
Reported	Employee reported the phishing email to the security team	Positive — enables rapid detection and campaign shutdown	↑ Increase — high reporting enables faster incident response

6.2 Pre-Training KPI Results — All Departments

Department	🔴 Clicked	🔴 Submitted Credentials	🟢 Reported
IT	15	4	2
Sales	30	29	0
Procurement	15	4	2
Audit	35	8	1
Marketing	33	30	0

Critical Pre-Training Finding

The pre-training data reveals a severe security awareness gap across all measured departments:

- Sales: 29 out of 30 employees who clicked the link also submitted their credentials (97% submission rate)
- Marketing: 30 out of 33 who clicked also submitted credentials (91% submission rate)
- Marketing: Zero employees reported the phishing email before training
- Sales: Only 1 employee out of the entire department reported the email

In a real attack, this level of credential submission would result in mass account compromise, with no departmental detection capability. The data makes a compelling case for immediate security awareness intervention.

04 **Security Awareness Training** **ISO 27001 A.6.3 Training Delivery**

7. Phase 4 — Security Awareness Training

Following the baseline phishing simulation, a structured security awareness training programme was delivered to all employees across the five departments. The training was designed to directly address the specific vulnerabilities demonstrated by the pre-training KPI data — focusing on phishing recognition, safe email handling, credential hygiene, and the critical importance of reporting.

7.1 Training Curriculum

#	Training Module	Key Learning Points
1	**What is Phishing?**	Types of phishing: spear phishing, whaling, vishing, smishing. How attackers craft convincing lures. The LinkedIn phishing campaign was used as a live example.
2	**Recognising Phishing Emails**	Check the sender's full email address (not just display name). Look for urgency and fear-based language. Verify unexpected requests through a separate channel. Check links before clicking — hover to see the real URL.
3	**LinkedIn-Specific Threats**	LinkedIn credential theft is one of the most common corporate phishing vectors. Attackers use harvested LinkedIn credentials for BEC reconnaissance, corporate espionage, and credential stuffing. Always log in directly to LinkedIn.com — never via email links.
4	**What to Do If You Click**	Do NOT enter credentials on any unexpected page. Close the browser immediately. Report to the security team as a Priority 1 incident. Change your LinkedIn password from a known-safe device.
5	**The Critical Role of Reporting**	Reporting a phishing email to security — even if you did not click — helps the entire organisation. A single report enables the security team to block the phishing domain and alert all other employees within minutes. Reporting is not admitting a mistake — it is a security control.
6	**Credential Hygiene**	Use unique passwords for all accounts. Enable MFA on LinkedIn and all other professional accounts. Never reuse your corporate email password on any external platform.

05 **Post-Training KPI Measurement** **Simulation Round 2**

8. Phase 5 — Post-Training KPI Measurement

Following the completion of the security awareness training programme, the identical phishing simulation was re-run against all five departments. The same Zphisher LinkedIn clone methodology, the same email template, and the same delivery timing were used — ensuring the only variable between Round 1 and Round 2 was the security awareness training received by employees.

8.1 Post-Training KPI Results — All Departments

Department	🟢 Clicked (After)	🟢 Submitted (After)	🟢 Reported (After)
IT	1	0	15
Sales	2	0	30
Procurement	1	0	15
Audit	2	0	31
Marketing	2	0	35

06 **KPI Analysis — Before vs After Comparison** **Training Effectiveness Measurement**

9. Phase 6 — KPI Analysis: Before vs After Comparison

9.1 Full Comparison Table

Dept.	Clicked			Submitted			Reported		
	Before	After	Δ Change	Before	After	Δ Change	Before	After	Δ Change
IT	15	1	↓ 93%	4	0	↓ 100%	2	15	↑ 650%
Sales	30	2	↓ 93%	29	0	↓ 100%	0	30	↑ 3000%
Procurement	15	1	↓ 93%	4	0	↓ 100%	2	15	↑ 650%
Audit	35	2	↓ 94%	8	0	↓ 100%	1	31	↑ 3000%
Marketing	33	2	↓ 94%	30	0	↓ 100%	0	35	↑ ∞

9.2 Headline KPI Achievements — Confirmed Departments

100% Credential Submission Drop (All 3 Depts)

93–94% Click Rate Reduction

0 → 35 Marketing Reporting (Zero to 35)

3,000% Sales Reporting Rate Increase

9.3 Department-by-Department Analysis

IT Department

The IT department showed strong post-training improvement. Click rate fell from 15 to 1 — a 93% reduction. More importantly, credential submissions dropped from 4 to zero, eliminating the account compromise risk. The reporting rate increased from 2 to 15 — a 650% increase — demonstrating that IT staff, once trained, actively engaged with the reporting process. The single residual click (without submission) is consistent with a technically curious user investigating the phishing link rather than falling for it.

Sales Department

Sales showed the most dramatic turnaround. Pre-training, 29 of 30 employees who clicked also submitted credentials — a near-total department compromise in a single phishing campaign. Post-training, clicks fell from 30 to 2 and submissions fell to zero. Reporting surged from 0 to 30

— a 3,000% increase. The Sales department transformed from the organisation's highest-risk department to one of its most engaged security responders. This result directly validates the training's effectiveness with the highest-risk cohort.

Marketing Department

Marketing had the highest pre-training click and submission rates (33 clicked, 30 submitted) and the lowest reporting rate (zero). Post-training, clicks fell from 33 to 2 (94% reduction), submissions fell to zero (100% reduction), and reporting rose from zero to 35 — the highest reporting count of any department. Marketing's transformation from zero reporters to the top-reporting department is the single most striking result of the campaign and demonstrates that even the highest-risk population can be transformed with targeted training.

10. Security Awareness Findings & Departmental Risk Profile

10.1 Pre-Training Risk Matrix

Department	Click Risk	Submission Risk	Reporting Capability	Overall Pre-Training Risk
IT	**Medium**	Low-Medium	Very Low	MEDIUM — Technical awareness reduced but did not eliminate risk
Sales	**CRITICAL**	**CRITICAL (97%)**	Negligible	CRITICAL — Near-total department compromise risk in a single campaign
Procurement	**Medium**	Low-Medium	Very Low	MEDIUM — Technical awareness lowered the risk but did not fully mitigate it.
Audit	**CRITICAL**	High	Very Low	High —- low report capability and high submission risk
Marketing	**CRITICAL**	**CRITICAL (91%)**	**None (0 reports)**	CRITICAL — Highest risk department: maximum exposure with zero detection capability

11. ISO 27001 Annex A 6.3 Compliance Evidence Summary

The table below maps each requirement of ISO 27001:2022 Annex A Control 6.3 to the specific project activity and evidence produced — providing a complete audit-ready compliance record.

#	A.6.3 Requirement	Evidence Produced	Status	Section
1	Awareness: All personnel receive security awareness	Phishing simulation delivered to all 5 departments — 100% employee population coverage	**COMPLIANT ✓**	Section 5
2	Education: Training covers policies and procedures relevant to their function	Training curriculum included LinkedIn-specific threats (relevant to Sales/Marketing functions) and reporting procedures	**COMPLIANT ✓**	Section 7
3	Training: Structured training on how to recognise and respond to threats	6-module training programme: phishing recognition, LinkedIn threats, reporting, credential hygiene	**COMPLIANT ✓**	Section 7
4	Regular updates: Training effectiveness is measured and repeated	Pre and post-training KPI measurement provides quantified effectiveness data. Repeatable methodology established for ongoing quarterly campaigns	**COMPLIANT ✓**	Sections 6,8,9
5	Measurable improvement: Evidence that training is effective	100% credential submission reduction; 93-94% click rate reduction; 650-3000% reporting increase across measured departments	**COMPLIANT ✓**	Section 9

12. Recommendations

12.1 Immediate Actions

- Require all Sales and Marketing employees to enrol in LinkedIn MFA — the two departments with the highest pre-training submission rates must have additional authentication protection in place immediately
- Block all non-HTTPS links in inbound emails at the email gateway — while the Zphisher link used HTTPS, blocking HTTP-only phishing links provides an immediate additional layer of protection
- Implement email authentication controls (DMARC, DKIM, SPF) if not already in place — these controls prevent sender spoofing, which was a key element of the phishing email's credibility

12.2 Short-Term (30 Days)

- Collect and insert the missing Procurement and Audit department KPI data — the compliance record is incomplete without these two departments. Schedule a focused simulation if data was not captured
- Establish a formal phishing reporting inbox (e.g. phishing@organisation.com) — the training emphasised reporting but employees need a clear, frictionless channel. A dedicated mailbox with an auto-reply acknowledgement increases reporting rates further
- Run a follow-up simulation within 30 days specifically targeting the 5 employees who still clicked post-training (3 across IT, Sales, Marketing) — these individuals require additional targeted coaching

12.3 Strategic (Quarterly Cadence)

- Establish a quarterly phishing simulation programme — awareness training effectiveness decays without reinforcement. The methodology documented in this report provides a repeatable template for quarterly campaigns
- Vary the phishing lure by campaign — LinkedIn in Q1, Microsoft 365 in Q2, DocuSign in Q3, payslip/payroll theme in Q4 — to build resilience against different social engineering scenarios relevant to each department
- Introduce phishing simulation results into departmental performance reviews — not to penalise individuals, but to create a shared team accountability for security culture improvement
- Target 0 clicks and 100% reporting rate as the long-term goal — this is achievable within 12 months based on the trajectory demonstrated in this campaign

13. Key Lessons

#	Lesson	Detail
L-1	**Phishing simulations are the most effective security awareness measurement tool**	No other training mechanism produces the same quality of quantified, behavioural evidence as a live phishing simulation. Annual policy acknowledgement tick-boxes do not reveal whether employees can actually recognise a phishing attempt. This campaign produced precise, department-level data that a static questionnaire never could.
L-2	**LinkedIn is a highly effective phishing lure for corporate targets**	The near-100% pre-training submission rates in Sales and Marketing validate that LinkedIn credential requests are perceived as highly legitimate by employees who use the platform daily. Attackers know this — LinkedIn phishing is consistently among the top 5 most reported phishing themes in global threat intelligence reports.
L-3	**The reporting metric is as important as the click metric**	A department that clicks and reports is more valuable to the security team than a department that does not click but also does not report. Marketing's transformation from zero reporters to 35 reporters is operationally significant — a single early report from any employee can trigger a response that protects the entire organisation before most employees have even opened the email.
L-4	**High-risk departments are also the most trainable**	Marketing had the worst pre-training profile (33 clicked, 30 submitted, 0 reported) and the best post-training improvement (2 clicked, 0 submitted, 35 reported). This demonstrates that high-risk behaviour driven by unfamiliarity with security threats is more correctable through training than risk driven by technical complexity.
L-5	**Credential submission must be the primary zero-tolerance target**	Clicking a phishing link exposes the user to drive-by malware but does not by itself cause account compromise. Submitting credentials does. The 100% credential submission reduction across all three measured departments is therefore the most critical outcome of this campaign — it eliminates the highest-severity attack pathway.

14. Screenshot Evidence Index

#	Screenshot Caption	Section	Source
1	Kali Linux — Zphisher Cloned & Running (zphisher.sh launch screen)	4.1 — Zphisher Setup	Kali Linux Terminal
2	Zphisher — LinkedIn Clone Active (Phishing URL Generated)	4.2 — LinkedIn Clone	Kali Linux Terminal
3	Browser — LinkedIn Clone Page (Visual Appearance)	4.2 — Clone Appearance	Browser on Kali
4	Phishing Email — Inbox View (Sender + Subject Line)	5.2 — Email Delivery	Email Client Inbox
5	Phishing Email — Full Body with Verify Account Button	5.2 — Email Body	Email Client
6	Zphisher Terminal — Credential Capture (Redacted Submission)	5.3 — Credential Capture	Kali Linux Terminal
7	KPI Evidence — BEFORE Training (All Departments)	6.2 — Pre-Training KPIs	KPI Spreadsheet / Image
8	Security Awareness Training — Delivery Session Screenshot	7 — Training Delivery	Training Platform / Slide
9	KPI Evidence — AFTER Training (All Departments)	8.1 — Post-Training KPIs	KPI Spreadsheet / Image
10	KPI Comparison — Before and After (KPIs_before_and_after.png)	9.3 — Before vs After	Project KPI Image

End of Phishing Simulation & Security Awareness Campaign Documentation

ISO 27001 Annex A 6.3 | Zphisher | LinkedIn Clone | 5 Departments | Before & After KPI Evidence